

Project 3 - Cybersecurity Analytics

**Data Breach at SimonMed Imaging by the Ransomware Group
Medusa – Summary Report**

Introduction

The Medusa ransomware group is a rising threat actor in the 2025 ransomware network. Ransomware attack denied access to your data by encrypting it and demanding a ransom payment for decryption. These attacks continue to be one of the most disruptive and costly cyber-attacks facing in healthcare organizations like SimonMed Imaging. Healthcare networks contain a large amount of sensitive data, including protected health information (PHI), which needs to be protected to keep these documents confidential and available.

According to the Center for Strategic and International Studies (CSIS), the ransomware group Medusa claimed responsibility for a data breach involving SimonMed Imaging, during which hackers exfiltrated data belonging to approximately 1.2 million patients. The attackers demanded a ransom of one million dollars to delete the stolen data, which indicates the value of data and requirement of ransomware attacks.

In response to these kinds of attacks, it is important to know how these attack teams operate. The MITRE ATT&CK framework provides a structured model for analyzing adversary behavior across the cyber kill chain. This report examines how the Medusa ransomware group may use five enterprise tactics including Reconnaissance, Initial Access, Credential Access, Privilege Escalation, and Exfiltration to achieve its objectives.

Enterprise Tactics

The ransomware group Medusa may use following enterprise tactics to achieve their goal, which compromised SimonMed Imaging Healthcare Organization network.

1. Reconnaissance

This is the initial stage which attackers follow to gather information about their target organization to use later in the attack stage. The team Medusa would start to collect data from publicly available information from the SimonMed Imaging website, social media platforms, and professional networking sites. They also consider common factors related to healthcare environment like employee email formats, third-party vendors, exposed services, and technologies used for imaging, billing, or electronic health records. They can gather all email and contact number details of the high-value targets such as administrative staff or IT personnel using company website and other third-party vendors.

After gathering all information Medusa team can conduct phishing attacks to high value targets in the SimonMed Imaging Organization. Also, they can do active scanning to find open ports, exposed services and other details related to organization network. These reconnaissance activities are difficult to detect from the organization side, and this is the safest stage for the attackers to gather valuable data to accomplish their goal.

2. Initial Access

The objective of this stage is to test if the information the team Medusa found leads to successful exploitation. The healthcare organizations are mostly vulnerable to phishing attacks due to high volume of email communication and the urgent clinical operation which needs approvals. So, most probably team Medusa gains initial access through Phishing attacks. These attacks typically involve spear-phishing emails crafted to appear legitimate, such as messages related to medical imaging reports, insurance claims, or vendor invoices. These emails are designed to create a sense of urgency that pressures recipients into clicking links or opening attachments without careful examination. When a target recipient opens a malicious attachment or clicks a compromised link, malware is downloaded onto the system, granting team Medusa an initial foothold within the SimonMed Imaging organization network.

File Transfer Protocol (FTP) may also present an initial access risk. FTP transmits data without encryption, making it unsuitable for transferring sensitive files securely. If SimonMed Imaging uses FTP services, Medusa could exploit weak authentication or capture credentials in cleartext, allowing attackers to access or transfer files from internal systems.

Remote access technology is also used to gain initial access in healthcare environments. Services such as remote desktop services or VPN portals, if misconfigured or protected by weak credentials, may be exploited by attackers using stolen or guessed login information obtained through phishing campaigns. Once the Medusa team found credentials from compromised users, it can be used to gain immediate access to remote services without triggering alarms.

Even if SimonMed Imaging organization follows strict policies to mitigate cybersecurity incidents, a single employee mistake is enough to compromise whole system without triggering their alarm systems. After gaining initial access to the SimonMed Imaging organization, the team Medusa can proceed to credential access, privilege escalation, data exfiltration, and ultimately ransomware deployment.

3. Credential Access

After gaining initial access to the SimonMed Imaging network, team Medusa would try to obtain valid credentials to expand their access. This can be achieved through credential dumping, where attackers extract usernames and passwords from system memory or cached authentication stores. Attackers also can list out all the files including hidden files to obtain valuable information related to user credentials. For example, they can observe *.bash_history* files in Linux systems which may reveal previously executed commands, accessed directories, or installed programs that can provide insight into user behavior or credentials.

These credentials may be shared credentials or weak passwords used by the employees. Those stolen credentials will allow attackers to authenticate the organization network as legitimate users, making malicious activities more difficult to recognize from normal behavior.

4. Privilege Escalation

After credential access, the team Medusa seeks to escalate privileges to administrative or system-level control. Privilege escalation may involve exploiting misconfigurations, abusing legitimate system tools, or leveraging compromised administrator credentials. Achieving elevated privileges allows attackers to disable security controls, access sensitive servers, and prepare the environment for ransomware deployment.

This stage is particularly critical for healthcare organizations like SimonMed Imaging, as privilege escalation can grant attackers control over critical systems such as electronic health record servers, imaging platforms, and file shares.

5. Exfiltration

According to the MITRE ATT&CK framework, exfiltration refers to techniques adversaries use to transfer stolen data from a victim's environment to attacker-controlled systems. In this situation, exfiltration occurs prior to ransomware deployments, which allows Medusa team to threaten public disclosure of sensitive data if ransom demands are not met. These data are high value sensitive data which include protected health information (PHI), diagnostic images, billing records, insurance data, electronic health record (EHR) databases, and file server contents.

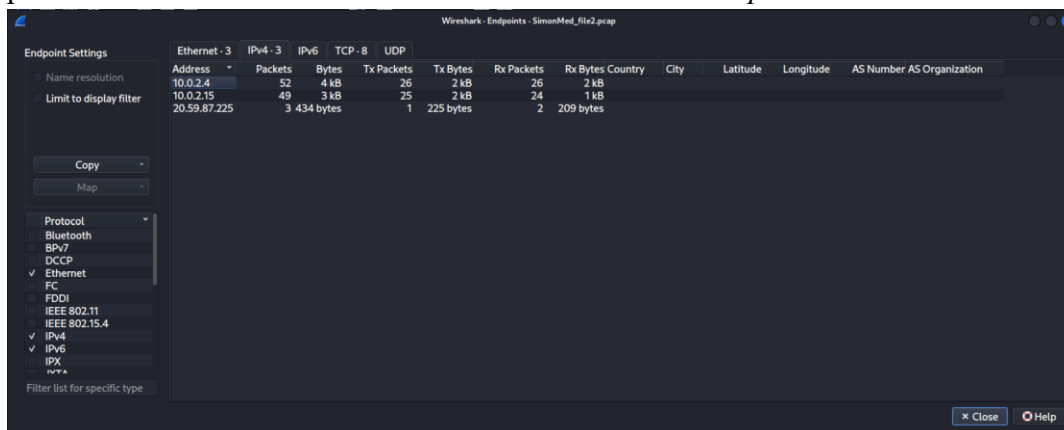
Medusa commonly uses exfiltration over command-and-control (C2) channels, which aligns with MITRE ATT&CK technique. Then attackers can blend exfiltration traffic with normal outbound communications to reduce the likelihood of detection.

Indicators of Compromise Detection using Wireshark

To identify indicators of compromise associated with the Medusa ransomware scenario, the packet capture file *SimonMed_file2.pcap* was analyzed using Wireshark.

1. Endpoint Analysis

Open the pcap file, *SimonMed_file2.pcap* on Wireshark to capture the data. SimonMed Imaging provides their victim IP as 10.0.2.4. Used *Statistics > Endpoints* to search about *IPv4* details.



Found that Victim IP received 25 packets from the 10.0.2.15 IP and also received traffic from the external IP address 20.59.87.225. The presence of communication between the victim host and an unknown external IP address is a potential indicator of command-and-control (C2) or data exfiltration activity, which is commonly observed in ransomware attacks.

2. Port and Connection Analysis

The victim host on 10.0.2.4 established multiple TCP connections using ephemeral client ports 49674, 49855, 49856, and 49857 to remote services. The host, 10.0.2.15 accepted FTP control connection on ports 21 and used ephemeral data ports 29667 and 46032 for FTP data transfer channels. Also, the victim host made an outbound encrypted connection to 20.59.87.225 through TCP port 443 (HTTPS). This type of encrypted outbound traffic to an unfamiliar external IP address may indicate the use of an external relay or C2 infrastructure.

Wireshark - Endpoints - SimonMed_flt2.pcap

Endpoint Settings

Name resolution

Limit to display filter

Copy

Map

Protocol

Bluetooth

BPv7

DCCP

✓

 Ethernet

FC

FDDI

IEEE 802.11

IEEE 802.15.4

✓

 IPv4

✓

 IPv6

IPX

IRTA

Filter list for specific type

Ethernet - 3

IPv4 - 3

IPv6

TCP - 8

UDP

Address	Port	Packets	Bytes	Tx Packets	Tx Bytes	Rx Packets	Rx Bytes
10.0.2.4	49674	3	434 bytes	2	209 bytes	1	225 bytes
10.0.2.4	49855	33	2 kB	15	930 bytes	18	1 kB
10.0.2.4	49856	8	494 bytes	5	308 bytes	3	186 bytes
10.0.2.4	49857	8	614 bytes	4	228 bytes	4	386 bytes
10.0.2.15	21	33	2 kB	18	1 kB	15	930 bytes
10.0.2.15	29667	8	494 bytes	3	186 bytes	5	308 bytes
10.0.2.15	46032	8	614 bytes	4	386 bytes	4	228 bytes
20.59.87.225	443	3	434 bytes	1	225 bytes	2	209 bytes

✕ Close

🔗 Help

3. FTP Session Inspection and Credential Exposure

Used *ftp* display filter to follow up the session, and then Right clicked a packet and selected *Follow > TCP Stream* to see entire command exchange. Further found the details of login credentials in clear text, including username (USER jane), and password (PAS pwd2345). The server response “230 Login successful” confirmed that authentication was successful, indicating that valid credentials were used to access the internal system. This behavior demonstrates a clear case of credential access using valid accounts.

The exposure of credentials through an unencrypted protocol such as FTP represents a significant security weakness, particularly in a healthcare environment handling sensitive patient data.

```

220 (vsFTPd 3.0.5)
AUTH TLS
530 Please login with USER and PASS.
AUTH SSL
530 Please login with USER and PASS.
USER jane
331 Please specify the password.
PASS pwd2345
230 Login successful.
CWD /home/jane
250 Directory successfully changed.
TYPE A
200 Switching to ASCII mode.
PASV
227 Entering Passive Mode (10,6,2,15,115,227).
STOR ts.txt
150 Ok to send data.
226 Transfer complete.
TYPE I

```

4. Evidence of File Transfer and Exfiltration

Used `ftp.request.command == "STOR" || ftp.response.code == 226` filter command to check file transfers. This proves that file exfiltration from the victim host.

No.	Time	Source	Destination	Protocol	Length	Info
22	0.294686	10.0.2.4	10.0.2.15	FTP	67	Request: STOR ts.txt
32	0.318149	10.0.2.15	10.0.2.4	FTP	78	Response: 226 Transfer complete.
47	0.367832	10.0.2.15	10.0.2.4	FTP	78	Response: 226 Directory send OK.

Summary of Findings

The Wireshark analysis identified multiple indicators of compromise consistent with ransomware-related activity. These included successful FTP authentication using cleartext credentials, internal lateral access between hosts, file transfer activity, and encrypted outbound communication to an external IP address.

Finally, these findings demonstrate how insecure protocols, credential exposure, and abnormal outbound traffic can be leveraged by ransomware groups such as team Medusa to gain access, expand control, and exfiltrate sensitive data from a healthcare network like SimonMed Imaging.

Severity	Finding	Evidence	Impact
High	Cleartext FTP Authentication	<i>USER jane / PASS pwd2345</i> visible in TCP stream	Immediate unauthorized access, credential leakage
High	Successful FTP Login	<i>230 Login successful</i> response	Confirms attacker gained authenticated access
High	File Transfer Activity	<i>STOR command + 226 Transfer complete</i>	Indication data exfiltration
High	Encrypted Outbound HTTPS Traffic	Connection to 20.59.87.225 via TCP 443	Possible external relay or C2 channel
Medium	Internal Lateral Access	10.0.2.4 accessing 10.0.2.15	Lateral movement and expand
Medium	Use of Insecure Protocol (FTP)	Unencrypted file transfer	Increases likelihood of credential theft

Conclusion

The data breach at SimonMed Imaging healthcare organization implies that important of cybersecurity practices to protect from attack teams like Medusa. By analyzing Medusa's behavior using the MITRE ATT&CK framework, this report demonstrates how the group progresses through reconnaissance, initial access, credential access, privilege escalation, and exfiltration. Each stage contributes something to achieve their final goal of compromising the whole network and exfiltration sensitive data from the SimonMed Imaging network. The combination of operational disruption and potential data exposure leads the organization to face legal actions, financial damage, and reputational damage.

Using cyber analytics tools like Wireshark provides valuable visibility into network activity and enables identification of indicators of compromise. Through network traffic analysis, suspicious behaviors such as cleartext credential exposure, unauthorized access, file transfer activity, and encrypted outbound communication can be detected before widespread damage occurs. SimonMed Imaging needs to have strong access control, and security awareness training to employees to mitigate these kinds of attacks.

References

1. Sanders, C. (2017). Practical packet analysis (3rd ed.).
2. Easttom, C. (2023). Computer Security Fundamentals (5th ed.). Pearson Education.
3. Center For Strategic and International Studies (CSIS). Significant Cyber Incidents. <https://www.csis.org/programs/strategic-technologies-program/significant-cyber-incidents>
4. MITRE ATT&CK. <https://attack.mitre.org/>